Chapter 9: Handling Compliance and Regulation

In previous chapters, we covered cloud infrastructure fundamentals and common threats in cloud environments. This chapter will cover security standards related to cloud services and compliance with some of the common regulations.

Standards ensure that we follow best practices in the same way as most organizations around the world in various fields, such as information security, privacy and data protection, health, finance, and more.

Compliance in cloud services is the act of complying with regulatory requirements and industry standards. Complying with laws, regulations, and standards enables organizations to conduct their business in a secure manner, by ensuring that customer data remains protected.

In this chapter, we will cover the following topics:

- Compliance and the shared responsibility model
- Introduction to compliance with regulatory requirements and industry best practices
- What are the common **International Organization for Standardization (ISO)**standards related to cloud computing?
- What is a **System and Organization Controls (SOC)** report?
- What is the **Cloud Security Alliance (CSA) Security, Trust, Assurance, and Risk (STAR)** program?
- What is the **Payment Card Industry Data Security Standard (PCI DSS)**?
- What is the **General Data Protection Regulation (GDPR)**?

- What is the **Health Insurance Portability and Accountability Act (HIPAA)**?

Technical requirements

For this chapter, the reader needs to have a solid understanding of information security concepts such as standards, compliance programs, data protection, and others.

Compliance and the shared responsibility model

According to the shared responsibility model (as explained in ***Chapter 1***, *Introduction to Cloud Security*), the cloud provider in **infrastructure as a service/platform as a service (IaaS/PaaS)** is responsible for the physical aspects of the cloud (from physical data centers, hardware, storage, network equipment, host servers, to virtualization).

Software as a service (SaaS) providers are also responsible for application layers (guest **operating system (OS)**, managed databases, managed storage, application tier, and more). As customers, we expect our cloud providers to be both compliant with regulatory requirements (such as protecting credit card information in PCI DSS, protecting **personally identifiable information (PII)** in GDPR, and more) and to work according to the highest security standards (such as ISO *27001*, SOC, and more).

When we as organizations serve customers, we need to be compliant with regulations (when dealing with financial, healthcare, or personal data), whether we build our infrastructure above IaaS/PaaS or serve customers as SaaS providers. When we serve customers as SaaS providers, our customers expect us to work according to the highest security standards and we need to prove to our customers that our security controls are effective.

To prove that a cloud provider is compliant with security best practices, the cloud providers pass an assessment by third-party assessors—neutral

security vendors (such as major accountant firms). The reason for using third-party assessors is because we, as customers, have no way of checking either the physical, logical, or procedural effectiveness of cloud vendors who make their own self-assessments.

Introduction to compliance with regulatory requirements and industry best practices

Law and regulations are mandatory for any organization conducting business, storing and processing sensitive data (such as PII, credit card information, healthcare information, and more), and serving customers in either private or public environments, and the cloud environment is no different.

Standards are optionally considered as a best practice and, in many cases, provide an organization leverage for conducting business—for example, compliance with ISO *27001* shows customers and business partners that an organization has achieved a certain level of maturity in **information security management** (**ISM**).

The best way to manage compliance in cloud services as an automated and ongoing process is to constantly review your entire cloud environment, present the information, dashboards, and reports, and fix settings

How to maintain compliance in AWS

Amazon Web Services (**AWS**) offers its customers a service called **AWS Config** that allows customers to continuously check their entire AWS organization's compliance status against regulatory requirements and industry best practices. To review an up-to-date list of compliance reports that AWS is compliant against, you can use **AWS Artifact**.

For more information, refer to the following resources:

AWS Artifact

https://aws.amazon.com/artifact

AWS Config

https://docs.aws.amazon.com/config/latest/developerguide/conformancepack-sample-templates.html

How to maintain compliance in Azure

Azure offers its customers a service called **Microsoft Defender for Cloud** that allows them to continuously check their entire Azure tenant's compliance status against regulatory requirements and industry best practices. Through Azure, customers can review an up-to-date list of compliance reports that Azure is compliant against, as appears in the **Azure Trust Center**.

For more information, refer to the following resources:

Azure Security Center—Improve your regulatory compliance

https://docs.microsoft.com/en-us/azure/security-center/security-center-compliance-dashboard

Azure Trust Center

https://www.microsoft.com/en-ww/trust-center/compliance/compliance-overview

Microsoft Azure Compliance Offerings

https://azure.microsoft.com/mediahandler/files/resourcefiles/microsoft-azure-compliance-offerings/Microsoft%20Azure%20Compliance%20Offerings.pdf

How to maintain compliance in GCP

Google Cloud Platform (**GCP**) offers its customers a service called **Google Security Command Center**, which allows customers to continuously check their entire GCP organization's compliance status against regulatory requirements and industry best practices.

GCP also allows its customers the ability to review an up-to-date list of compliance reports that GCP is compliant with, as appears in the **Google Compliance Reports Manager**.

For more information, refer to the following resources:

Google Security Command Center compliance dashboard:

https://cloud.google.com/security-command-center/docs/how-to-use-security-command-center#compliance

Google Compliance Reports Manager:

https://cloud.google.com/security/compliance/compliance-reports-manager

Summary

In this section we reviewed the industry best practices to maintain compliance in AWS, Azure, and GCP.

What are the common ISO standards related to cloud computing?

ISO is a non-governmental international organization that publishes documents and raises awareness for standards in various topics and, in the context of this book, standards related to information security and cloud services.

ISO/IEC 27001 standard

The ISO/**International Electrotechnical Commission (IEC)** *27000* standard is the most widely used standard for ISM. Though it is not cloud-specific, it is considered the most fundamental standard for **cloud service providers (CSPs)**, and it sets a solid foundation for any cloud provider, from a hyper-scale cloud provider to a small SaaS provider.

The ISO *2700x* is split into the following sections:

- ISO/IEC *27000:2018* provides an overview of **ISM systems (ISMS)**.
- ISO/IEC *27001:2013* is a standard for ISM.
- ISO/IEC *27002:2013* specifies best practices for ISM.

The ISO *27001* is made of the following domains:

- Information Security Policies
- Organization of Information Security
- Human Resources Security
- Asset Management
- Access Control
- Cryptographic
- Physical and Environmental Security
- Operations Security
- Communications Security
- System Acquisition, Development, and Maintenance
- Supplier Relationship
- Information Security Incident Management
- Information Security Business Continuity Management
- Compliance

For more information, refer to the following resources:

ISO/IEC 27001 INFORMATION SECURITY MANAGEMENT

https://www.iso.org/isoiec-27001-information-security.html

AWS—ISO/IEC 27001:2013

https://aws.amazon.com/compliance/iso-27001-faqs/

Azure—ISO/IEC 27001:2013

https://docs.microsoft.com/en-us/azure/compliance/offerings/offering-iso-27001

GCP—ISO/IEC 27001

https://cloud.google.com/security/compliance/iso-27001

ISO 27017 standard

The ISO/IEC *27017* is a set of guidelines for information security controls applicable to cloud services, based on ISO/IEC *27002*. Since ISO *27017* is based on ISO *27002*, most of the controls are the same.

Any organization that provides cloud services should consider complying with the ISO *27017* standard. ISO *27017* adds the following controls:

- Shared roles and responsibilities within a cloud computing environment
- Removal of cloud service customer assets
- Segregation in virtual computing environments
- **Virtual machine** (**VM**) hardening
- Administrator's operational security
- Monitoring of cloud services
- Alignment of security management for virtual and physical networks

For more information, refer to the following resources:

ISO/IEC 27017:2015

https://www.iso.org/standard/43757.html

AWS—ISO/IEC 27017:2015 Compliance

https://aws.amazon.com/compliance/iso-27017-faqs/

Azure—ISO/IEC 27017:2015

https://docs.microsoft.com/en-us/azure/compliance/offerings/offering-iso-27017

GCP—ISO/IEC 27017

https://cloud.google.com/security/compliance/iso-27017

ISO 27018 standard

ISO/IEC *27018* is a set of guidelines for implementing measures to protect PII for cloud services, based on ISO/IEC *27002*. As ISO *27018* is based on ISO *27002*, most of the controls are the same.

Any organization that provides cloud services and stores or processes PII should consider complying with the ISO *27018* standard. ISO *27018* adds the following controls:

- **Customers' rights**:
  - Ability to access their data
  - Ability to erase their data
  - Know the purpose of processing their data
- **Service provider (SP) obligations**:
  - Process data disclosure requests from customers
  - Document all data disclosure requests
  - Audit all access attempts to customers' data
  - Notify customers about sub-contractors with access to customers' personal data
  - Notify customers about data breaches relating to their personal data
  - Document all policies and procedures relating to customers' personal data
  - Encrypt all customers' personal data at rest (including backups)
  - Data deletion procedures
  - Notify customers about countries where their data is been stored and processed

For more information, refer to the following resources:

ISO/IEC 27018:2019

https://www.iso.org/standard/76559.html

AWS—ISO/IEC 27018:2019 Compliance

https://aws.amazon.com/compliance/iso-27018-faqs

Azure—ISO/IEC 27018:2019

https://docs.microsoft.com/en-us/azure/compliance/offerings/offering-iso-27018

GCP—ISO/IEC 27018

https://cloud.google.com/security/compliance/iso-27018

Summary

In this section, we have reviewed the ISO standards and the controls required by cloud providers to be compliant with the ISO standards mentioned previously.

ISO *27001* is recommended for any organization maintaining environments in the public cloud, whether you are a cloud provider or whether you maintain your own IaaS environment.

ISO *27017* is recommended for any cloud provider who offers services to customers over the public cloud; this standard is complementary to ISO *27001*.

From a customer's point of view (organizations that consume cloud services), it is recommended to increase your compliance requirements from cloud providers and demand compliance with both ISO *27001* and ISO *27017*.

ISO *27018* is recommended for any cloud provider that stores or processes customers' PII.

From a customer's point of view (organizations that consume cloud services), it is recommended to increase your compliance requirements from cloud providers and demand compliance with ISO *27001*, ISO *27017*, and ISO *27018*, for any service you consume that stores or processes your PII.

What is a SOC report?

SOC is a reporting framework that allows cloud providers to communicate the effectiveness of their cybersecurity risk management program to **certified public accountants (CPAs)** and broad-range stakeholders—customers, among others.

Any organization that provides cloud services should consider complying with the SOC standard. A SOC is made up of the following type of reports:

- **SOC 1**—A financial statement:
  - **SOC 1 Type 1**—An attestation of controls for a CSP at a specific point in time
  - **SOC 1 Type 2**—An attestation of controls for a CSP and their effectiveness over a minimum 6-month period
- **SOC 2**—A report of controls relevant to security, availability, integrity, and confidentiality or privacy
  - **SOC 2 Type 1**—A description of cloud providers' systems and suitability of the design of controls
  - **SOC 2 Type 2**—A description of cloud providers' systems and suitability of the design of controls and the effectiveness of controls
    NOTE
    From a customer's point of view, SOC 2 Type 2 is the most relevant report since it presents the actual effectiveness of the cloud provider's security controls.
- **SOC 3**—A management report that contains an assurance about the controls of the cloud provider, relevant to security, availability, integrity, and confidentiality or privacy
  NOTE
  SOC 3 reports are high-level reports and, as a result, they are publicly shared with customers.

For more information, refer to the following resources:

System and Organization Controls: SOC Suite of Services

https://www.aicpa.org/interestareas/frc/assuranceadvisoryservices/sorhome.html

AWS System and Organization Controls (SOC)

https://aws.amazon.com/compliance/soc-faqs/

Azure—System and Organization Controls (SOC) 1 Type 2

https://docs.microsoft.com/en-us/compliance/regulatory/offering-soc-1

GCP—SOC 2

https://cloud.google.com/security/compliance/soc-2

Summary

In this section, we have reviewed SOC reports, their levels, and the importance of reviewing SOC 2 Type 2 reports by customers to get a better understanding of cloud providers' effectiveness in terms of security controls.

From a customer's point of view (organizations that consume cloud services), it is recommended to increase your compliance requirements from cloud providers and demand a copy of SOC 2 Type II reports from any public cloud provider.

What is the CSA STAR program?

The CSA is an organization that publishes documents, best practices, and raises awareness for cloud security.

Any organization that provides cloud services should consider being compliant with the CSA STAR program. The CSA has created two documents related to cloud security, as follows:

- **Cloud Control Matrix (CCM)**—A cybersecurity control framework for cloud computing
- **Consensus Assessment Initiative Questionnaire (CAIQ)**—A set of industry-accepted security controls for IaaS/PaaS/SaaS services

The CSA has created a program called STAR that is an open registry of cloud providers who publicly share their security controls for the various service models and allow customers to download and review the vendor's compliance against industry best practices.

STAR Level 1

STAR Level 1 is a self-assessment questionnaire where cloud providers transparently share their security controls.

Customers should use a self-assessment questionnaire as a good starting point for low-risk environments since the questionnaire was not reviewed for the effectiveness of the controls by an independent third-party auditor.

STAR Level 2

STAR Level 2 offers cloud providers who already have compliance with ISO *27001*, SOC 2 reports, and more the ability to have their security controls be reviewed by a third-party auditor and adds a level of comfort for the cloud provider's self-assessment questionnaire to the customer by evaluating the actual effectiveness of controls declared by the cloud provider. Customers should use STAR Level 2 compliance for medium-to-high-risk environments, and to increase assurance for cloud security and privacy.

For more information, refer to the following resources:

Cloud Controls Matrix (CCM)

https://cloudsecurityalliance.org/research/cloud-controls-matrix/

CSA Star

https://cloudsecurityalliance.org/star/

AWS and Cloud Security Alliance (CSA)

https://aws.amazon.com/compliance/csa/

Azure—Cloud Security Alliance (CSA) STAR Certification

https://docs.microsoft.com/en-us/azure/compliance/offerings/offering-csa-star-certification

GCP and Cloud Security Alliance (CSA)

https://cloud.google.com/security/compliance/csa

Summary

In this section, we have reviewed the CSA STAR program, based on the CCM. For medium-to high-risk environments, customers should look for cloud providers who have received CSA STAR Level 2 certification.

What is PCI DSS?

PCI DSS is an information security standard for storing, transferring, and processing credit card information, created by MasterCard, American Express, Visa, JCB International, and Discover Financial Services.

Any organization storing or processing credit card information should comply with PCI DSS. The PCI has the following requirements:

- Use a firewall to protect the PCI environment
- Set password policies
- Protect stored credit card data
- Encrypt credit card data at transit

- Use anti-virus software
- Conduct patch management
- Restrict access to credit card data
- Assign a unique identity to each person with access to credit card data
- Restrict physical access to credit card data
- Conduct log management
- Conduct vulnerability assessments and penetration tests
- Conduct risk assessments and document the process

Any provider or organization that stores, transfers, or processes credit card information should follow the PCI DSS standard. As a best practice, follow your cloud provider's documentation regarding which services and controls to use to be compliant with the PCI standard and keep credit card information safe.

For more information, refer to the following resources:

PCI Security Standards

https://www.pcisecuritystandards.org/

Information Supplement: PCI SSC Cloud Computing Guidelines

https://www.pcisecuritystandards.org/pdfs/PCI_SSC_Cloud_Guidelines_v3.pdf

Payment Card Industry Data Security Standard (PCI DSS) 3.2.1 on AWS

https://d1.awsstatic.com/whitepapers/compliance/pci-dss-compliance-on-aws.pdf

Azure—Control mapping of the PCI-DSS v3.2.1 blueprint sample

https://docs.microsoft.com/en-us/azure/governance/blueprints/samples/pci-dss-3.2.1/control-mapping

GCP—PCI Data Security Standard compliance

https://cloud.google.com/architecture/pci-dss-compliance-in-gcp

Summary

In this section, we have reviewed the PCI DSS standard, as it relates to cloud services. If your organization is storing, transferring, or processing credit card information, you should separate your PCI environment from the rest of your cloud environments, and follow both PCI guidelines and your cloud provider's documentation and best practices.

What is the GDPR?

The GDPR is a European data protection regulation, aimed to protect the personal data of **European Union** (**EU**) citizens.

Any organization storing or processing information about EU citizens must comply with the GDPR. It defines personal data as any information that is related to an identified or identifiable natural person. GDPR applies to any organization that processes or collects personal data of EU citizens, either within data centers in Europe or to/from outside Europe.

These are the main GDPR chapters dealing with technical measures that might be related to cloud services:

- ***Chapter 2***—*Principles*
- ***Chapter 3***—*Rights of the data subject*
- ***Chapter 4***—*Controller and processor*
- ***Chapter 5***—*Transfer of personal data to third countries or international organizations*
- ***Chapter 9*** —*Provisions relating to specific processing situations*

Here are some practices for protecting personal data:

- Encrypt all personal data while at transit (use **Transport Layer Security** (**TLS**) 1.2) or at rest (use the **Advanced Encryption Standard** (**AES**) 256 algorithm).
- Make sure the cloud provider offers you the ability to control the encryption keys (**customer-managed keys**).

- Enforce the use of **multi-factor authentication** (**MFA**) for any user who has access to personal data.
- Follow the principle of *need to know*.
- Make sure EU citizens' personal data is kept in data centers inside the EU, or within data centers of countries that receive an adequate level of data protection from the EU.
- Make sure you sign a *data processing agreement* with your cloud provider.
- Make sure the cloud provider has performed security audits by a third-party auditor before processing personal data.
- Collect only the minimal required personal data.
- Make sure you can locate personal data and erase it, following the customer's request.

For more information, refer to the following resources:

General Data Protection Regulation

https://gdpr-info.eu/

Code of Conduct for GDPR

https://cloudsecurityalliance.org/artifacts/pla-code-of-conduct-coc-statement-of-adherence-self-assessment/

Navigating GDPR Compliance on AWS

https://docs.aws.amazon.com/whitepapers/latest/navigating-gdpr-compliance/welcome.html

Azure—General Data Protection Regulation Summary

https://docs.microsoft.com/en-us/compliance/regulatory/gdpr

Azure—European Union Model Clauses

https://docs.microsoft.com/en-us/compliance/regulatory/offering-eu-model-clauses

Google Cloud & the General Data Protection Regulation (GDPR)

https://cloud.google.com/security/gdpr

GCP—EU Model Contract Clauses

https://cloud.google.com/security/compliance/eu-mcc

Summary

In this section, we have reviewed the GDPR—a European data protection regulation, related to any organization worldwide that collects or processes personal data of EU citizens. As a best practice, follow your cloud provider's documentation regarding which services or controls to use while designing new systems or to be compliant with the GDPR.

What is HIPAA?

HIPAA is a United States Act for organizations dealing with electronic healthcare transactions and PIIs in the healthcare and healthcare insurance industries.

These are the main HIPAA security rules:

- Administrative Safeguards
- Physical Safeguards
- Technical Safeguards
- Organizational, Policies and Procedures and Documentation Requirements
- Basics of Risk Analysis and Risk Management

Here are some best practices to implement:

- Encrypt all healthcare information, while in transit (using TLS 1.2) or at rest (using the AES 256 algorithm).
- Enable an audit log for any information related to healthcare data.
- Authenticate and authorize any request to access healthcare data.

- Follow the *principle of least privilege* (**POLP**) when accessing healthcare data.
- Conduct penetration testing for systems that contain healthcare data.
- Keep all systems up to date (enforce patch management).
- Enable backups for any system that contains healthcare data.

For more information, refer to the following resources:

Summary of the HIPAA Privacy Rule

https://www.hhs.gov/hipaa/for-professionals/privacy/laws-regulations/index.html

Guidance on HIPAA & Cloud Computing

https://www.hhs.gov/hipaa/for-professionals/special-topics/health-information-technology/cloud-computing/index.html

Architecting for HIPAA Security and Compliance on Amazon Web Services

https://d1.awsstatic.com/whitepapers/compliance/AWS_HIPAA_Compliance_Whitepaper.pdf

Azure—HIPAA

https://docs.microsoft.com/en-us/azure/compliance/offerings/offering-hipaa-us

A Practical Guide to Designing Secure Health Solutions Using Microsoft Azure

https://azure.microsoft.com/mediahandler/files/resourcefiles/a-practical-guide-to-designing-secure-health-solutions-using-microsoft-azure/A_Practical_Guide_to_Designing_Secure_Health_Solutions_using_Microsoft_Azure.pdf

GCP—HIPAA

https://cloud.google.com/security/compliance/hipaa-compliance

Google Cloud Platform HIPAA overview guide

https://services.google.com/fh/files/misc/google-cloud-platform-hipaa-overview-guide.pdf

Summary

In this section, we have reviewed the HIPAA Act, which relates to any organization dealing with US healthcare information. As a best practice, follow your cloud provider's documentation regarding how to protect healthcare data.

Summary

In this chapter, we have focused on compliance with common regulations and standards while using cloud services. For each of the mentioned regulations or standards, we have reviewed its highlights and some best practices for either cloud providers or customers (organizations consuming cloud services). The mentioned regulations or standards might be relevant when dealing with certain types of data or certain types of cloud environments.

For each of the mentioned regulations or standards, we have supplied references on how to be compliant while working with AWS, Azure, and GCP. From a customer point of view, knowing which security standards exist will allow you to set the security prerequisites from your cloud providers. Knowing which law or regulation applies to your industry will allow you to know which security controls to set for your cloud environments.

In the next chapter, we will review how to engage with cloud providers—how to choose a cloud provider, cloud provider questionnaires, important topics regarding contracts with cloud providers, and, finally, tips for conducting penetration tests in cloud environments.